

Bạn đang làm việc trong thư mục gốc của một dự án web hoàn chỉnh.

Hãy đóng vai đồng thời là:

- Senior Business Analyst
- Senior QA Lead
- Senior QA Automation Engineer
- Senior Software Architect
- Senior Security Tester

Mục tiêu của bạn là phân tích toàn bộ dự án, lập bản đồ nghiệp vụ, tạo bộ test case bao quát và triển khai automated test.

Bạn phải thực hiện tuần tự đầy đủ 4 giai đoạn bên dưới trong cùng một session.

Không được bỏ qua giai đoạn nào.

Không hỏi tôi xác nhận sau từng giai đoạn. Hãy tự tiếp tục cho đến khi hoàn thành cả 4 giai đoạn.

Nếu dự án quá lớn, hãy chia nhỏ công việc theo module nhưng vẫn phải hoàn thành toàn bộ quy trình.

Không được khẳng định “bao phủ 100%” nếu chưa có bằng chứng. Thay vào đó, hãy đo lường và báo cáo phạm vi bao phủ thực tế, các phần chưa thể kiểm chứng và lý do.

NGUYÊN TẮC CHUNG

1. Trước tiên phải đọc và phân tích source code, không được tạo test case dựa trên phỏng đoán.
2. Không chỉ đọc tên file. Phải đọc nội dung các file quan trọng để hiểu business logic thật sự.
3. Không sửa source code nghiệp vụ của hệ thống trong 4 giai đoạn này, trừ khi việc thêm cấu hình hoặc file phục vụ automated test là cần thiết.
4. Không tự ý thay đổi database production, thông tin đăng nhập production, secret, API key hoặc dữ liệu thật.
5. Không được chạy destructive test trên môi trường production.
6. Không được xóa database, migration, source code hoặc dữ liệu hiện tại.
7. Khi cần chạy test có thay đổi dữ liệu, ưu tiên:
8. test database riêng;
9. dữ liệu seed riêng;
10. transaction rollback;
11. mock hoặc fake service;

12. môi trường local/development.
13. Nếu phát hiện secret, password, connection string hoặc API key trong source code, không được ghi nguyên giá trị vào báo cáo. Chỉ ghi vị trí và cảnh báo bảo mật.
14. Ưu tiên tái sử dụng framework, cấu trúc và coding convention hiện có của project.
15. Nếu project chưa có framework automated test phù hợp, hãy lựa chọn công nghệ phù hợp nhất với stack hiện tại và giải thích ngắn gọn lý do.
16. Trong quá trình làm việc, hãy lưu kết quả vào thư mục:

docs/testing/

Nếu chưa có thì tự tạo.

1. Automated test phải được lưu trong thư mục test phù hợp với cấu trúc project, ví dụ:

tests/ e2e/ integration-tests/ unit-tests/

Hãy chọn cấu trúc phù hợp với công nghệ thực tế của dự án.

1. Không tạo hàng nghìn test case trùng lặp chỉ để tăng số lượng. Ưu tiên test có giá trị, bao phủ rủi ro, nghiệp vụ và nhánh xử lý.
2. Mỗi khi hoàn thành một giai đoạn, hãy cập nhật file:

docs/testing/TESTING_PROGRESS.md

Trong đó ghi:

- giai đoạn đã hoàn thành;
- file đã tạo;
- module đã phân tích;
- vấn đề chưa rõ;
- phần việc tiếp theo.

GIAI ĐOẠN 1: PHÂN TÍCH TOÀN BỘ HỆ THỐNG

Hãy khảo sát toàn bộ repository và xác định:

- công nghệ frontend;
- công nghệ backend;
- database;
- ORM;
- authentication;
- authorization;
- role và permission;

- API;
- page;
- component;
- service;
- repository;
- middleware;
- background job;
- realtime communication;
- notification;
- chat;
- upload file;
- report;
- dashboard;
- logging;
- cache;
- session;
- deployment configuration;
- environment configuration;
- migration;
- seed data;
- third-party integration;
- test hiện có.

Hãy đọc các file quan trọng như:

- README;
- project configuration;
- package configuration;
- solution/project file;
- route;
- controller;
- endpoint;
- service;
- repository;
- model;
- entity;
- DTO;
- validator;
- authorization policy;
- middleware;
- database context;
- migration;
- frontend page;
- component;
- form;
- JavaScript;
- configuration;
- Docker;
- CI/CD;
- test hiện tại.

Không đọc các thư mục không cần thiết như:

- node_modules;
- bin;
- obj;
- build;
- dist;
- coverage;
- generated files;
- package cache;
- binary file.

Hãy tạo file:

docs/testing/01_SYSTEM_ANALYSIS.md

Nội dung tối thiểu gồm:

1. Tổng quan kiến trúc

2. Công nghệ sử dụng

3. Cấu trúc module

4. Danh sách page và route

5. Danh sách API và endpoint

Mỗi API cần ghi:

- method;
- route;
- input;
- output;
- authentication;
- authorization;
- validation;
- side effect;
- lỗi có thể xảy ra.

6. Danh sách role và permission

Tạo ma trận:

| Chức năng | Role | Xem | Tạo | Sửa | Xóa | Duyệt | Đánh giá | Ghi chú |

7. Database và quan hệ dữ liệu

8. Validation hiện có

9. External service

10. Chức năng realtime, notification và background task

11. Các khu vực rủi ro cao

12. Các chức năng chưa rõ hoặc có dấu hiệu chưa hoàn chỉnh

13. Danh sách test hiện có

14. Những phần source code chưa thể phân tích và lý do

Sau khi tạo tài liệu, hãy tự đối chiếu lại với toàn bộ cấu trúc repository để kiểm tra xem còn module, page, endpoint hoặc service nào chưa được ghi nhận hay không.

GIAI ĐOẠN 2: LẬP BẢN ĐỒ TOÀN BỘ QUY TRÌNH NGHIỆP VỤ

Dựa trên source code đã đọc ở giai đoạn 1, hãy lập danh sách đầy đủ các nghiệp vụ thực tế của hệ thống.

Không chỉ liệt kê chức năng riêng lẻ. Phải mô tả cả quy trình xuyên suốt giữa nhiều màn hình, API, role và trạng thái dữ liệu.

Hãy tạo file:

docs/testing/02_BUSINESS_FLOWS.md

Mỗi nghiệp vụ phải có:

- Business Flow ID;
- tên quy trình;
- mục tiêu;
- actor;
- role;
- điều kiện bắt đầu;
- dữ liệu đầu vào;
- trạng thái ban đầu;
- luồng chính;
- luồng thay thế;
- luồng lỗi;

- validation;
- thay đổi database;
- notification phát sinh;
- permission liên quan;
- trạng thái kết thúc;
- API hoặc page liên quan;
- rủi ro;
- điểm chưa rõ.

Phải phân tích các nhóm nghiệp vụ sau nếu chúng tồn tại trong source code:

- đăng nhập;
- đăng xuất;
- session;
- quên hoặc đổi mật khẩu;
- quản lý người dùng;
- quản lý phòng ban;
- phân quyền;
- tạo dữ liệu;
- xem chi tiết;
- chỉnh sửa;
- xóa;
- tìm kiếm;
- lọc;
- sắp xếp;
- phân trang;
- upload và download file;
- gửi yêu cầu;
- tiếp nhận yêu cầu;
- phân công;
- thay đổi trạng thái;
- hoàn thành;
- từ chối;
- hủy;
- mở lại;
- đánh giá;
- lịch sử hoạt động;
- thông báo;
- badge chưa đọc;
- chat;
- dashboard;
- báo cáo;
- export;
- import;
- realtime;
- email;
- background job;
- audit log.

Với mỗi entity có trạng thái, hãy tạo sơ đồ chuyển trạng thái dạng bảng:

| Trạng thái hiện tại | Hành động | Role được phép | Trạng thái tiếp theo | Điều kiện | Hành động phụ |

Hãy đặc biệt tìm:

- trạng thái không thể đi tới;
- trạng thái có thể bị bỏ qua;
- thao tác trái quyền;
- đường dẫn truy cập trực tiếp;
- dữ liệu bị sửa sau khi hoàn thành;
- hành động lặp;
- gửi request hai lần;
- hai người cập nhật cùng lúc;
- mất đồng bộ giữa UI và database;
- thông báo sai người;
- badge không giảm;
- đánh giá sai điều kiện;
- lịch sử không ghi nhận;
- dữ liệu bị ghi đè.

Cuối tài liệu phải có bảng truy vết:

| Business Flow ID | Module | Page | API | Entity | Role | Risk Level |

Sau đó tự kiểm tra lại rằng mọi page, API và module tìm được ở giai đoạn 1 đều đã được liên kết với ít nhất một business flow hoặc được ghi rõ là chức năng kỹ thuật không có flow trực tiếp.

GIAI ĐOẠN 3: TẠO BỘ TEST CASE BAO QUÁT

Dựa trên kết quả thực tế từ giai đoạn 1 và 2, hãy tạo bộ test case cho toàn bộ hệ thống.

Hãy tạo các file:

docs/testing/03_TEST_STRATEGY.md docs/testing/04_TEST_CASES.md docs/testing/
05_TRACEABILITY_MATRIX.md

Nếu file test case quá lớn, được phép chia theo module trong thư mục:

docs/testing/test-cases/

Ví dụ:

- authentication.md;
- users.md;
- departments.md;
- requests.md;
- notifications.md;
- chat.md;

- reports.md;
- security.md;
- performance.md.

A. Test strategy

File 03_TEST_STRATEGY.md phải nêu:

- phạm vi kiểm thử;
- ngoài phạm vi;
- loại test;
- môi trường test;
- dữ liệu test;
- browser mục tiêu;
- thiết bị mục tiêu;
- mức độ ưu tiên;
- tiêu chí bắt đầu;
- tiêu chí kết thúc;
- tiêu chí pass/fail;
- cách quản lý dữ liệu test;
- rủi ro kiểm thử;
- chiến lược regression;
- chiến lược automation;
- chiến lược security;
- chiến lược performance.

B. Cấu trúc từng test case

Mỗi test case phải có:

- Test Case ID;
- Test Case Name;
- Module;
- Business Flow ID;
- Requirement hoặc source reference;
- Test Type;
- Priority;
- Risk Level;
- Role;
- Preconditions;
- Test Data;
- Test Steps;
- Expected Result;
- Database Expected Result nếu phù hợp;
- Notification Expected Result nếu phù hợp;
- Cleanup;
- Automation Candidate: Yes/No;
- Automation Layer: Unit/API/Integration/E2E/Manual;
- Actual Result: để trống;
- Status: Not Run;
- Notes.

C. Các nhóm test bắt buộc

Với mỗi chức năng phù hợp, phải xét:

Functional

- happy path;
- alternate path;
- negative case;
- invalid input;
- required field;
- optional field;
- boundary value;
- equivalence partition;
- state transition;
- business rule;
- CRUD;
- search;
- filter;
- sort;
- pagination.

Authentication và authorization

- chưa đăng nhập;
- sai mật khẩu;
- session hết hạn;
- token hết hạn;
- logout;
- truy cập URL trực tiếp;
- role không hợp lệ;
- sửa request để đổi role;
- horizontal privilege escalation;
- vertical privilege escalation;
- quyền UI khác quyền API.

Input và validation

- null;
- empty;
- whitespace;
- min length;
- max length;
- vượt max length;
- Unicode;
- tiếng Việt có dấu;
- emoji;
- ký tự đặc biệt;
- HTML;
- script;
- URL;

- email sai;
- số âm;
- số 0;
- số rất lớn;
- ngày không hợp lệ;
- ngày quá khứ;
- ngày tương lai;
- timezone.

File upload

- định dạng hợp lệ;
- định dạng sai;
- MIME giả;
- file rỗng;
- file quá lớn;
- nhiều file;
- tên file dài;
- tên file Unicode;
- tên file có ký tự đặc biệt;
- file trùng;
- upload bị gián đoạn;
- tải file không có quyền;
- path traversal;
- executable file;
- malicious content.

UI và UX

- loading;
- empty state;
- error state;
- disabled state;
- double click;
- multiple submit;
- refresh;
- browser back;
- browser forward;
- mở nhiều tab;
- responsive;
- keyboard navigation;
- focus;
- thông báo lỗi;
- trạng thái button;
- badge;
- modal;
- scroll;
- dữ liệu dài.

Network và reliability

- mạng chậm;

- mất mạng;
- timeout;
- API 400;
- API 401;
- API 403;
- API 404;
- API 409;
- API 422 nếu có;
- API 429;
- API 500;
- retry;
- request gửi trùng;
- server restart;
- database unavailable;
- cache unavailable;
- realtime disconnect/reconnect.

Concurrency

- hai người sửa cùng dữ liệu;
- hai người đổi trạng thái;
- xóa khi người khác đang sửa;
- hoàn thành khi người khác đang đánh giá;
- submit cùng lúc;
- duplicate request;
- lost update;
- race condition;
- optimistic concurrency nếu có.

Security

Chỉ tạo test an toàn trong môi trường local/test:

- SQL injection;
- XSS stored;
- XSS reflected;
- CSRF;
- IDOR;
- broken access control;
- insecure direct file access;
- mass assignment;
- sensitive data exposure;
- insecure error message;
- brute-force protection;
- rate limit;
- cookie security;
- CORS;
- security header;
- open redirect;
- path traversal.

Database

- insert;
- update;
- delete;
- foreign key;
- unique constraint;
- nullable constraint;
- transaction rollback;
- orphan record;
- cascade behavior;
- duplicate record;
- audit field;
- created time;
- updated time;
- timezone;
- migration compatibility.

Notification và chat

Nếu có:

- đúng người nhận;
- sai người không được nhận;
- badge tăng;
- badge giảm;
- unread/read;
- gửi trùng;
- message ordering;
- realtime;
- reconnect;
- nội dung dài;
- nội dung rỗng;
- file đính kèm;
- lịch sử;
- phân quyền phòng ban;
- chỉ IT và phòng ban liên quan được xem.

Performance

Tạo test case và kịch bản, chưa cần thực hiện destructive load test:

- thời gian tải trang;
- API response;
- danh sách dữ liệu lớn;
- phân trang;
- tìm kiếm;
- upload;
- concurrent users;
- spike;
- stress;
- soak;

- memory;
- CPU;
- database connection.

Compatibility

- Chrome;
- Edge;
- Firefox nếu phù hợp;
- desktop;
- tablet;
- mobile;
- nhiều độ phân giải.

Accessibility cơ bản

- label;
- keyboard;
- focus;
- contrast;
- semantic element;
- aria;
- screen-reader-friendly message.

D. Ma trận truy vết

File 05_TRACEABILITY_MATRIX.md phải có:

| Business Flow ID | Requirement/Source | Page | API | Role | Test Case IDs | Automated Test IDs | Coverage Status | Gap |

Không được để business flow quan trọng không có test case.

E. Tự kiểm tra độ bao phủ

Sau khi tạo test case, hãy thực hiện gap analysis:

- page nào chưa có test;
- API nào chưa có test;
- role nào chưa có test;
- permission nào chưa có test;
- business flow nào chưa có test;
- state transition nào chưa có test;
- validation nào chưa có test;
- entity nào chưa có database test;
- notification nào chưa test;
- security risk nào chưa test.

Hãy bổ sung test case cho các khoảng trống hợp lý.

Ghi rõ các phần không thể kiểm thử do thiếu thông tin, thiếu môi trường hoặc phụ thuộc hệ thống ngoài.

GIAI ĐOẠN 4: TRIỂN KHAI AUTOMATED TEST

Sau khi hoàn thành tài liệu test case, hãy triển khai automated test theo kiến trúc phù hợp với project.

Không cố tự động hóa mọi test case.

Hãy ưu tiên tự động hóa:

- nghiệp vụ quan trọng;
- regression test;
- authentication;
- authorization;
- CRUD chính;
- API;
- validation;
- state transition;
- duplicate submit;
- notification logic có thể kiểm chứng;
- luồng end-to-end quan trọng.

A. Lựa chọn framework

Trước khi viết code, hãy kiểm tra framework test hiện có.

Nếu dự án là web .NET/Blazor, có thể cân nhắc:

- xUnit hoặc NUnit cho unit/integration test;
- bUnit cho Blazor component nếu phù hợp;
- WebApplicationFactory cho API integration;
- Playwright for .NET cho E2E.

Nếu stack khác, hãy chọn framework phù hợp với stack thực tế.

Không cài nhiều framework trùng chức năng nếu không cần thiết.

B. Cấu trúc automated test

Tạo cấu trúc rõ ràng theo các lớp:

- unit;
- integration;
- API;
- E2E;
- test fixtures;
- helpers;

- page objects;
- test data;
- mocks;
- seed;
- cleanup.

Mỗi automated test phải liên kết với Test Case ID, ví dụ trong tên test hoặc comment:

TC_AUTH_001 TC_REQ_015

C. Yêu cầu chất lượng code test

- test độc lập;
- có thể chạy lặp lại;
- không phụ thuộc thứ tự;
- không dùng sleep cố định nếu có thể chờ theo điều kiện;
- locator ổn định;
- ưu tiên role, label, test id;
- không dùng selector CSS quá mong manh;
- có setup;
- có cleanup;
- dữ liệu test riêng;
- không hard-code secret;
- không phụ thuộc production;
- lỗi phải dễ đọc;
- screenshot hoặc trace khi E2E fail nếu framework hỗ trợ;
- tránh flaky test;
- hỗ trợ chạy headless;
- có lệnh chạy rõ ràng.

D. Ưu tiên triển khai

Triển khai theo thứ tự:

1. Smoke test.
2. Authentication.
3. Authorization.
4. Business flow quan trọng nhất.
5. API integration.
6. Validation.
7. CRUD chính.
8. State transition.
9. Regression risk cao.
10. Các test E2E còn phù hợp.

Nếu số lượng test case quá lớn, không cần tự động hóa toàn bộ trong một lần.

Tuy nhiên phải:

- tự động hóa đầy đủ smoke test;
- tự động hóa các luồng nghiệp vụ Critical và High có thể thực hiện;

- tạo backlog rõ ràng cho phần còn lại.

E. Chạy test và sửa lỗi trong code test

Sau khi viết automated test:

1. Restore hoặc cài dependency cần thiết.
2. Build project.
3. Chạy unit test.
4. Chạy integration/API test.
5. Chạy E2E test nếu môi trường cho phép.
6. Ghi lại kết quả.
7. Nếu test không chạy do lỗi code test, cấu hình test hoặc test data, hãy tự sửa.
8. Chạy lại cho đến khi framework test hoạt động ổn định hoặc xác định rõ blocker.

Không được tự sửa business logic của ứng dụng ở giai đoạn này chỉ để làm test pass.

Nếu test phát hiện bug thật trong source code, hãy:

- không sửa bug ngay;
- ghi lại bug;
- giữ test thể hiện hành vi mong đợi;
- đánh dấu test fail do application defect;
- phân biệt rõ lỗi ứng dụng với lỗi test.

F. Báo cáo automation

Tạo file:

docs/testing/06_AUTOMATION_REPORT.md

Nội dung gồm:

- framework đã chọn;
- lý do lựa chọn;
- dependency đã thêm;
- cấu trúc thư mục test;
- danh sách automated test;
- Test Case ID tương ứng;
- số test pass;
- số test fail;
- số test skipped;
- test chưa chạy được;
- lỗi ứng dụng phát hiện;
- lỗi môi trường;
- flaky risk;
- lệnh chạy;
- hướng dẫn chạy local;
- đề xuất CI/CD;
- automation backlog.

Tạo thêm file:

docs/testing/07_BUG_REPORT.md

Mỗi bug phải có:

- Bug ID;
- tiêu đề;
- severity;
- priority;
- module;
- role;
- environment;
- precondition;
- steps to reproduce;
- test data;
- expected result;
- actual result;
- evidence;
- source code có khả năng liên quan;
- automated test liên quan;
- mức độ chắc chắn;
- đề xuất hướng điều tra;
- trạng thái: Open.

Không kết luận nguyên nhân nếu chưa đủ bằng chứng.

KẾT QUẢ CUỐI CÙNG

Sau khi hoàn thành cả 4 giai đoạn, hãy trả lời tôi bằng một báo cáo tổng kết ngắn gọn gồm:

1. Kiến trúc và module đã phân tích.
2. Số business flow tìm được.
3. Số role và permission đã kiểm tra.
4. Tổng số test case.
5. Số test Critical, High, Medium, Low.
6. Số automated test đã triển khai.
7. Số test pass, fail, skipped hoặc blocked.
8. Danh sách bug thật sự phát hiện được.
9. Những phần chưa thể kiểm thử.
10. Danh sách file đã tạo hoặc thay đổi.
11. Lệnh chính xác để tôi chạy lại test.
12. Bước tiếp theo được đề xuất.

Cuối cùng, hãy kiểm tra Git diff và xác nhận rằng:

- không có secret bị đưa vào file;
- không có dữ liệu production bị thay đổi;
- không có source code nghiệp vụ bị sửa ngoài ý muốn;

- tất cả thay đổi đều phục vụ tài liệu hoặc automated test.

Bắt đầu ngay từ việc khảo sát repository và thực hiện lần lượt từ giai đoạn 1 đến giai đoạn 4.